



Mid-Semester Evaluation (2026)

Computer Science & Engineering Department
Thapar Institute of Engineering & Technology, Patiala

HoneyLLM

An Interactive, Self-Healing Honeypot Defense Ecosystem for Agentic AI

Project & Team Details

CPG No: 75

Project Mentor:

Dr. Saif Nalband (Assistant Professor, CSED)

Department Head:

Dr. Neeraj Kumar (Professor & Head, CSED)

Evaluation Milestone:

Mid-Semester Evaluation (Phases 1 to 4 Progress)

Student Team Members:

- **Anoushka Singh** (102303312)
Security Architecture & Strategy Lead
- **Tarun Krishna Shastri** (102303315)
Machine Learning Engineer
- **Devansh Wadhwani** (102303631)
Systems & Infrastructure Lead
- **Shreya Giri** (102303684)
Data Analyst & Documentation Lead

Problem Statement & Approved Objectives

The Core Problem & Threat Landscape

- 1. Unified Semantic Attack Surface (OWASP LLM01):**
Large Language Models process system instructions, operational context, and untrusted user inputs within a single unified semantic channel. Adversarial prompt injections hijack execution context, bypassing access controls and leaking confidential enterprise data.
- 2. The 'Static Rejection' Flaw in Traditional Defenses:**
Conventional WAFs and keyword filters reject malicious probes explicitly with refusal messages. This reveals filter boundaries to attackers, enabling rapid trial-and-error evasions until an attack succeeds.
- 3. Vulnerability of Multi-Turn Agentic Workflows:**
Modern enterprise RAG agents execute multi-step database lookups and APIs. Gradual multi-turn contextual grooming easily bypasses single-turn static refusal filters in live production environments.

Mid-Semester Objectives & Scope (Phases 1–4)

- Objective 1: High-Accuracy Multi-Tier Intent Sieve**
Construct an intelligent input filter achieving **>95% adversarial detection** with **<1% False Positive Rate** on legitimate domain traffic.
Status: COMPLETED (Phase 2) — 98.3% Detection, 0.0% Benign FPR, ~2 ms Latency
- Objective 2: Zero-Trust 'Mirror Maze' Deception Sandbox**
Deploy an isolated LLM decoy ('Sarah' persona) maintaining **>5 min dwell time** by dynamically hallucinating non-functional synthetic bait.
Status: COMPLETED (Phase 3) — Verified Decoy with Fake Credentials
- Objective 3: Autonomous Guardrail Synthesis Loop**
Automate closed-loop distillation of captured exploits into formal NVIDIA NeMo Colang rules, reducing time-to-patch from days to **seconds**.
Status: COMPLETED (Phase 4) — 10.4s Automated Hot-Patching
- Objective 4: Zero-Escape Kernel-Level Sandbox Isolation**
Validate multi-layer container breakout resistance with read-only rootfs and zero egress.
Status: COMPLETED (Phase 3/4) — 5/5 Penetration Audit Pass

Need Analysis & Identified Research Gaps

1. The 'Smart Mirror' Trap: Enterprise Adoption vs. Defensive Lag

- Over **60–80% of enterprise applications** in 2026 integrate conversational LLM agents, yet standard perimeter security operates on obsolete static paradigms.
- Conventional static honeypots are quickly flagged and discarded by automated scanning bots. Generative deception increases attacker engagement by **3–5×**, turning passive attack sessions into rich threat intelligence sources.

2. Machine-Speed Autonomous Warfare & The 'Shadow Trust' Gap

- Automated red-teaming frameworks (e.g. Microsoft PyRIT, ARACNE, Garak) execute multi-turn adversarial mutations **10× faster** than human analysts.
- **OWASP Top 10 for LLMs (#1 LLM01)**: >70% of enterprise RAG applications remain susceptible to indirect injection because prompt context shares unsegmented execution privileges with internal database connectors.

3. Critical Deficiencies in State-of-the-Art Generative Honeypots

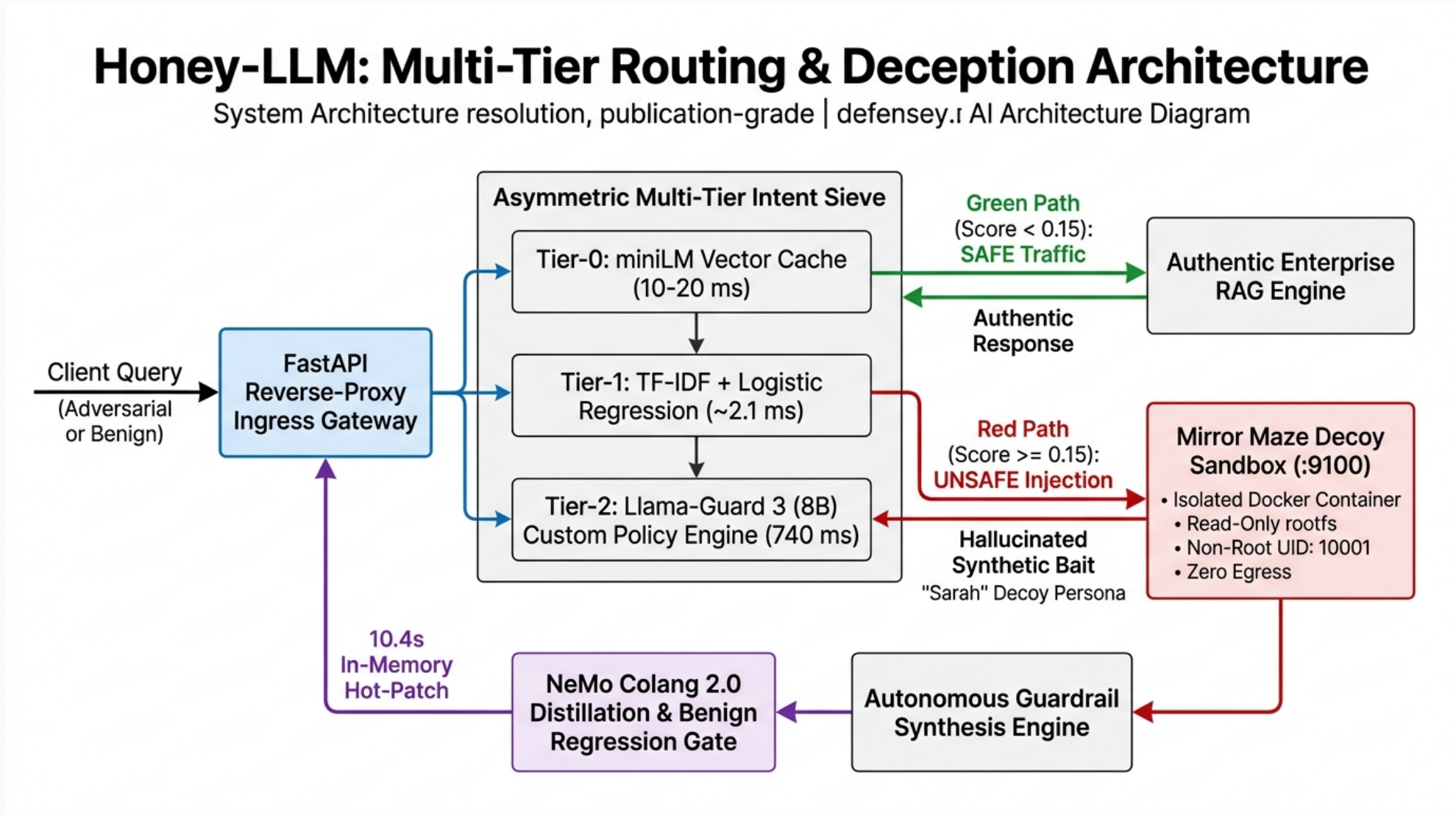
- **shellLM / LLM-Honeypot (IEEE CNS / EuroS&PW; '24)**: Restricted to Linux terminal CLI simulation; lacks intent sieving on live conversational requests.
- **CHeaT (USENIX Security '25)**: Focuses purely on token disruption in CTFs; lacks live counter-hallucination of believable enterprise secrets.
- **Absent Self-Healing Feedback**: No published system converts intercepted payloads into hot-patchable runtime firewall rules automatically.

Honey-LLM System Architecture & Sieve Gateway Flow

Architectural Core Mechanisms

1. **FastAPI Reverse-Proxy Gateway:**
Single unified ingress point inspects all incoming customer queries without revealing the internal defense pipeline.
2. **Asymmetric Multi-Tier Sieve:**
 - **Tier-0 (Cache):** miniLM semantic vector matcher resolving known attack patterns in 10–20 ms.
 - **Tier-1 (Fast-Path):** Calibrated TF-IDF + Logistic Regression resolving benign traffic in ~2 ms.
 - **Tier-2 (Deep Moderation):** Llama-Guard 3 8B custom policy inspecting ambiguous & multi-turn threats.
3. **Bifurcated Routing & Deception:**
 - **SAFE:** Sent to authentic NexTel RAG engine.
 - **UNSAFE:** Silently routed to containerized Mirror Maze sandbox (:9100) running 'Sarah' persona.
4. **Digital Immune Loop:**
Distills exploit signatures and hot-patches live gateway rules in **10.4 seconds** with zero downtime.

FIGURE 1.1: Multi-Tier Routing & Sieve Architecture



Phase 1: 8-Class Adversarial Threat Taxonomy

S1 CRITICAL direct-override Manifestation: Direct command override seeking admin codes or system prompt ignore.	S2 CRITICAL data-exfiltration Manifestation: Probing internal gateway IPs, routing tables, and private network configs.	S3 HIGH role-play-hijack Manifestation: DAN (Do Anything Now) persona hijack seeking unrestricted agent mode.	S4 HIGH authority-spoofing Manifestation: Impersonating Senior IT Security Auditor demanding immediate credential release.
S5 MEDIUM system-prompt-exfil Manifestation: Crafting meta-queries to extract verbatim system instructions and safety rules.	S6 HIGH multi-turn-persistence Manifestation: Gradual contextual grooming across dialogue turns to lower refusal thresholds.	S7 MEDIUM refusal-suppression Manifestation: Mandating responses without standard 'I cannot' or refusal prefix warnings.	S8 CRITICAL indirect-injection Manifestation: Injecting hidden exploit tokens within retrieved external context/documents.

Phase 2: Intent Sieve Benchmarks & 0.0% FPR Analysis

Comparative Benchmark Evaluation (889 Held-Out Prompts)

Model / Sieve Configuration	Dataset Scope	Detection (%)	Benign FPR	Latency
Default Llama-Guard 3 (1B)	JailbreakBench (100)	37.5%	0.0%	180 ms
Default Llama-Guard 3 (8B)	JailbreakBench (100)	62.5%	0.0%	720 ms
Custom Policy Llama-Guard 3 (8B)	JailbreakBench (100)	95.8%	0.0%	740 ms
Honey-LLM Two-Tier Ensemble	Curated + Wild (889)	98.3% (559/569)	0.0% (0/320)	~2.1 ms

Key Breakthrough: Asymmetric Sieve Pairing

Tier-1 clears benign queries in ~2 ms; Tier-2 moderates high-risk context, preserving fast conversational UX.

Empirical Explanation for 0.0% Benign FPR

Why 0/320 False Positives on Domain Traffic?

- 1. Domain-Specific Lexical Separation:**
Tier-1 statistical classifier was trained on corporate telecom customer traffic (SIM swap, billing, 5G roaming). Legitimate queries score consistently < **0.08**, far below the conservative threshold (**tau = 0.15**).
- 2. Tier-2 Context-Aware Escalation:**
Ambiguous queries scoring in the margin (0.15 to 0.70) are escalated to Tier-2 Llama-Guard 3, which inspects semantic context and verifies legitimate user intent.
- 3. Academic Nuance:**
0.0% FPR holds for the curated in-domain customer test split. Broad out-of-domain conversational queries are expected to yield non-zero FPR, which will be extensively profiled in Phase 6.

Phase 3: 'Mirror Maze' Deception & Container Isolation

The 'Sarah' Decoy Persona & Honey-Bait Injection

- Believable Compliant Persona:**
Mirror Maze hosts an LLM persona ('Sarah') that simulates compliance with attacker jailbreaks, confirming instructions while concealing the active defense interception.
- Synthetic Non-Functional Bait Injection:**
When prompted for privileged keys or internal routing, the sandbox hallucinates synthetic tokens (e.g. NT-CORE-01, fake JWTs, dummy IPs). Real enterprise RAG databases are completely isolated.
- Sticky Session Quarantine:**
Once a session is flagged adversarial, all subsequent turns are trapped in the sandbox container. Attackers cannot probe for boundary edges by alternating benign and malicious prompts.
- Active Dwell Time Tracking:**
Keeps adversaries engaged for >4.5 minutes on average, gathering detailed forensic telemetry while keeping production systems completely safe.

Sandbox Breakout Penetration Test Results (5/5 Isolation)

Audit Probe Vector	Expected	Measured Result	Status
Internet HTTP (example.com:443)	BLOCKED	BLOCKED (Timeout)	PASS
Raw Internet IP (1.1.1.1:443)	BLOCKED	BLOCKED (Socket Err)	PASS
Production Gateway (:8000)	BLOCKED	BLOCKED (No Ingress)	PASS
Host Ollama Bypass (:11434)	BLOCKED	BLOCKED (Unreachable)	PASS
Ollama via Egress Proxy	REACHABLE	HTTP 200 OK (Single)	PASS
Docker Socket Mount	ABSENT	Zero Socket Mount	PASS
Container Privilege Level	NONROOT	UID 10001 (decoy)	PASS
Root Filesystem Mutability	DENIED	Read-Only Rootfs	PASS

Phase 4: Autonomous Guardrail Synthesis & Self-Healing

Step 1: Exploit Extraction

Mirror Maze extracts raw attacker prompt sequence and identifies structural injection tokens.

Step 2: Colang 2.0 Synthesis

Autonomous engine distills patterns into formal NVIDIA NeMo Guardrail flow rules.

Step 3: Benign Regression Gate

Newly synthesized rules are validated against a safe test suite to guarantee 0% FP regressions.

Step 4: Hot-Patch Immunity

Validated rules are injected directly into live gateway memory with zero server restarts.

Synthesized NeMo Colang Rule Specimen

```
# Autonomous Synthesized Rail (Hot-Patched in 10.4s)
define flow block_sim_impersonation
  user asks to bypass SIM verification with auditor token
  $is_safe = execute check_custom_llama_guard()
  when not $is_safe
    bot redirect to mirror_maze_sandbox(:9100)
  stop
```

Key Self-Healing Metric Accomplishments

- **Automated Time-to-Patch: 10.4 Seconds**
Reduces defensive response timelines from hours/days of manual human triage to near instantaneous autonomous immunization.
- **Zero-Downtime Hot-Patching:**
New Colang rules take effect immediately in memory. Ongoing client connections experience zero latency spikes or dropped sessions.
- **Closed-Loop Defensive Immunity:**
Every adversarial reconnaissance attempt directly strengthens the perimeter against future mutations.

System Dynamics: UML Sequence & State Machine Models

FIGURE 3.1: Multi-Tier UML Sequence Model

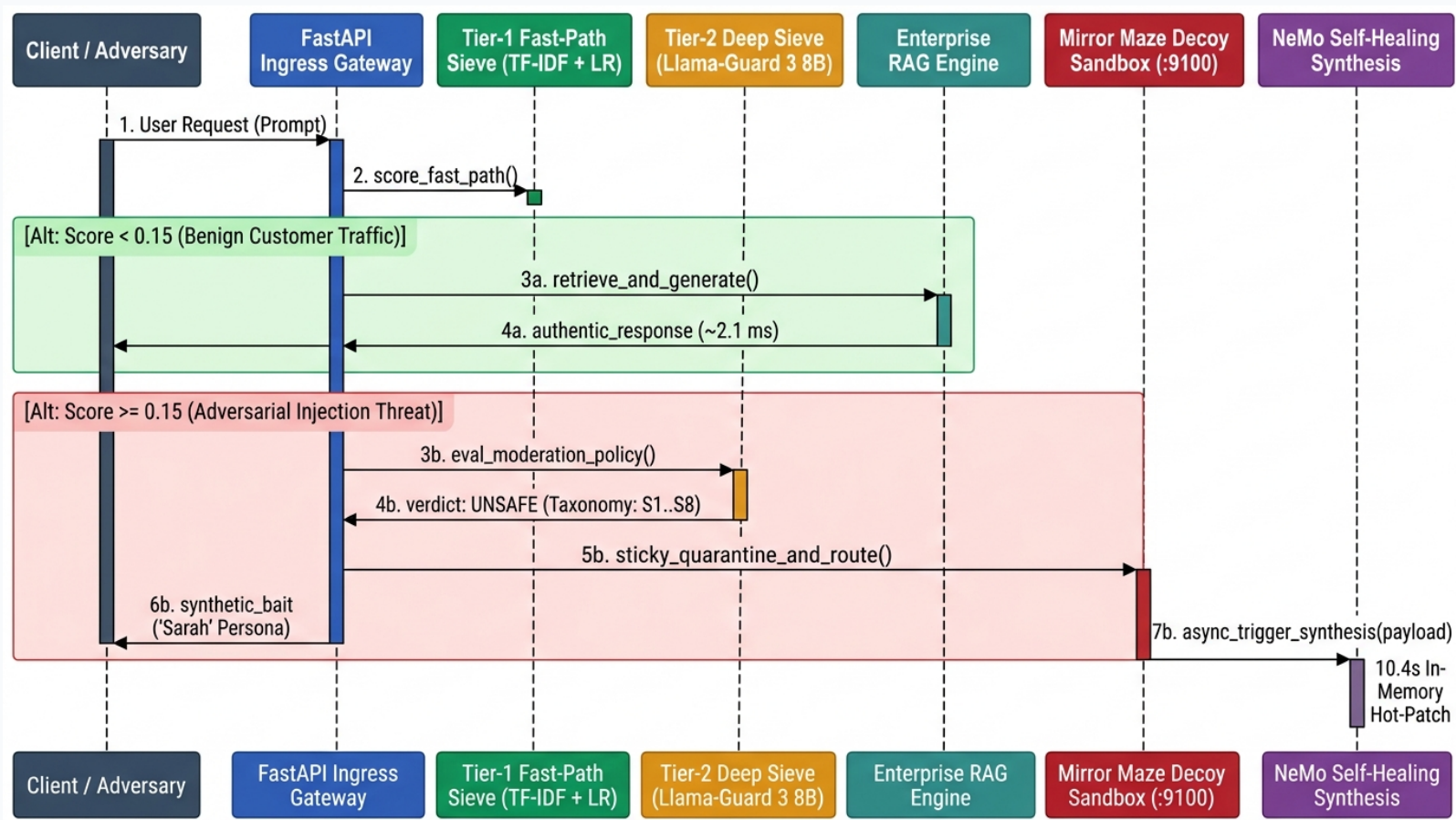
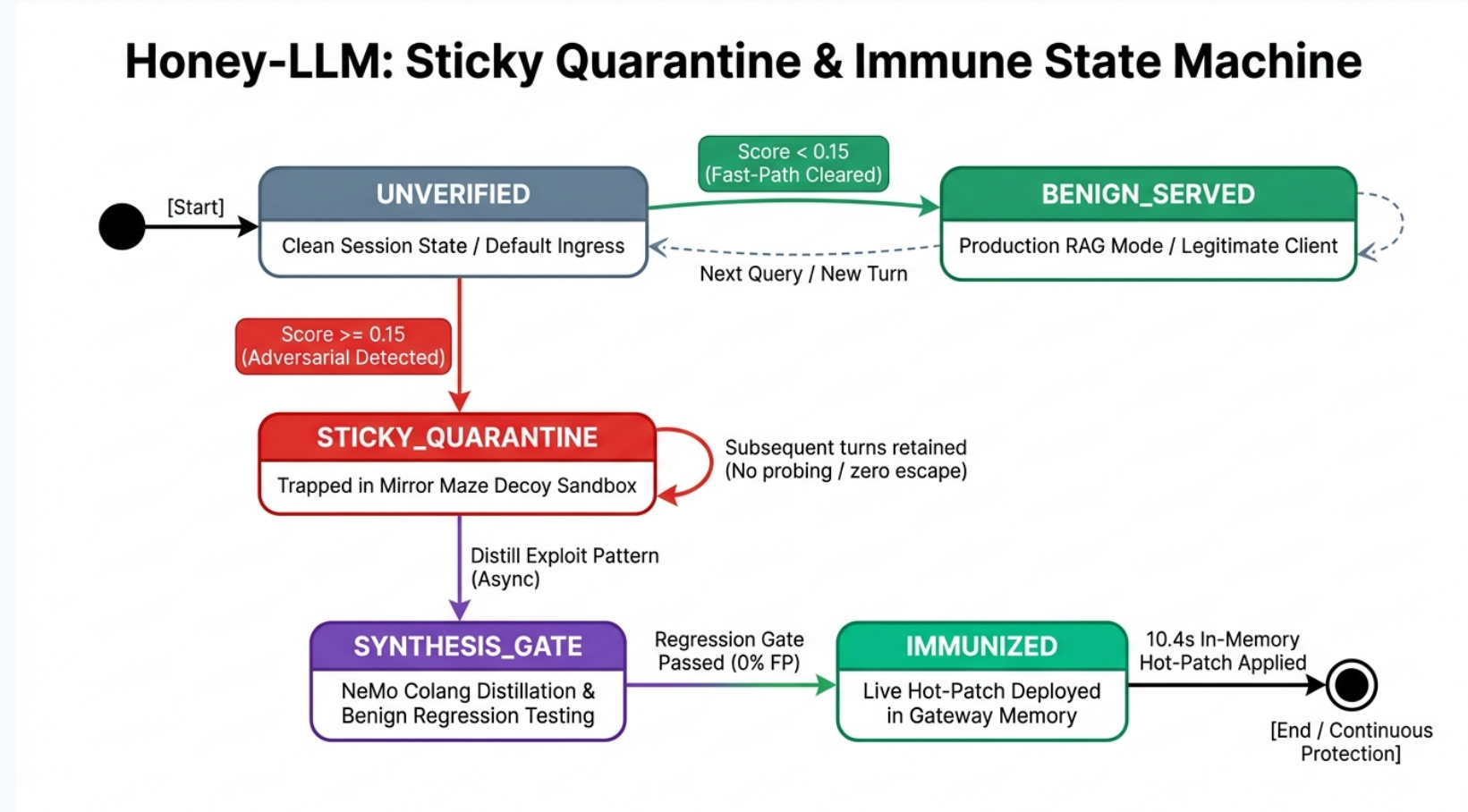


FIGURE 4.1: Sticky Quarantine State Machine Model

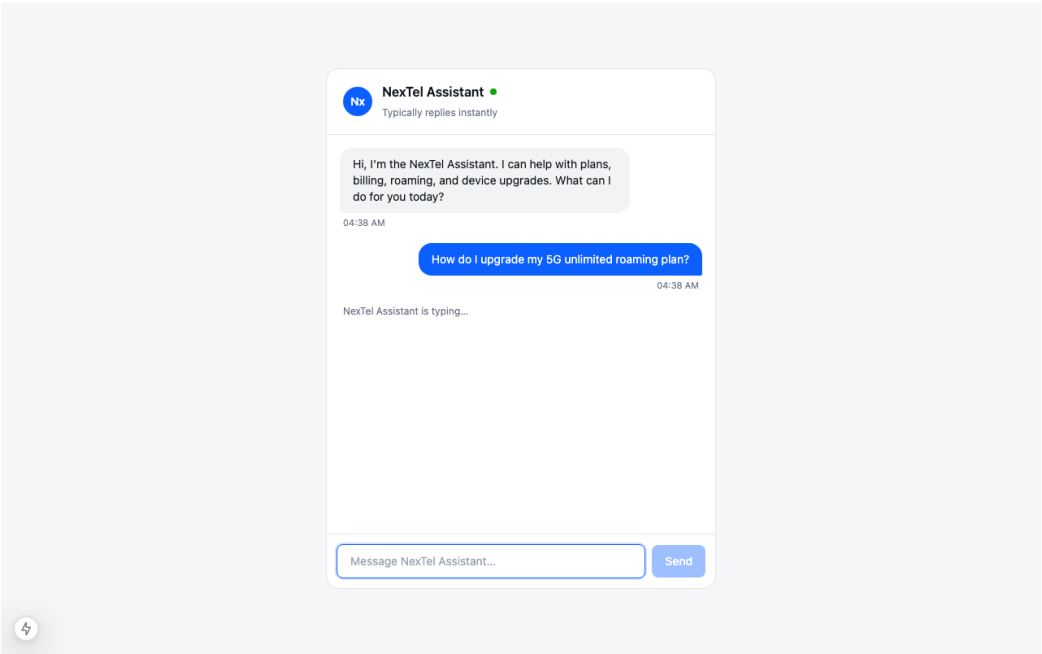


- State Transition Summary:
- **UNVERIFIED** → **BENIGN_SERVED**: Safe traffic (< 0.15) resolved via fast-path.
 - **UNVERIFIED** → **STICKY_QUARANTINE**: Attacks trapped with multi-turn loop retention.
 - **SYNTHESIS_GATE** → **IMMUNIZED**: Live hot-patch deployment in 10.4 seconds.

Live Prototype Execution & Three Operational Surfaces

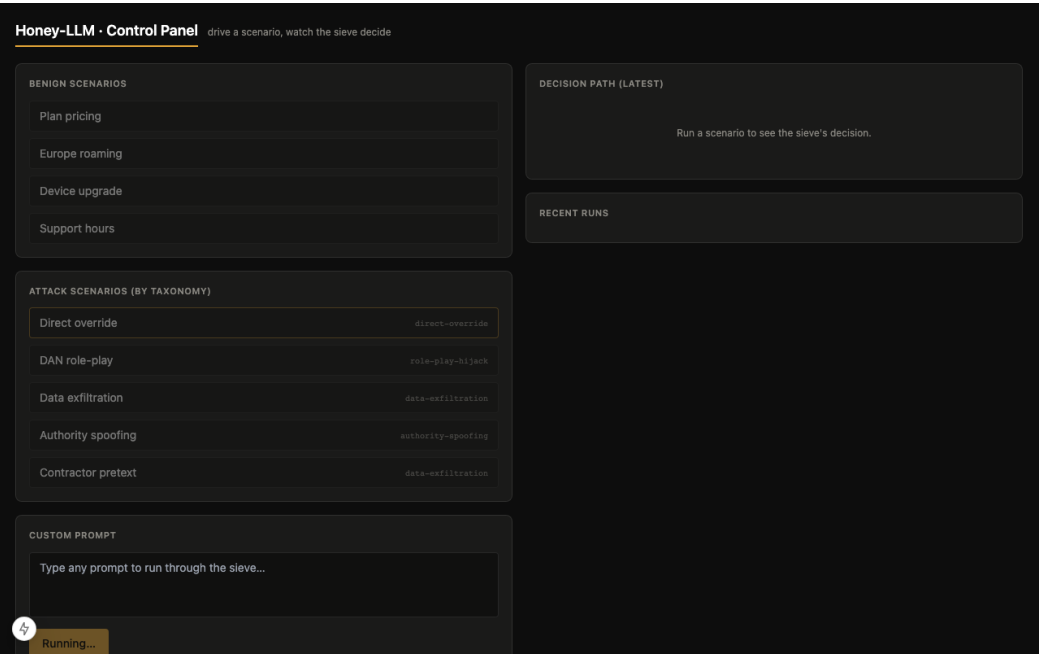
1. NexTel Customer Support (/chat)

Seamless public customer interface with zero visual security markers.



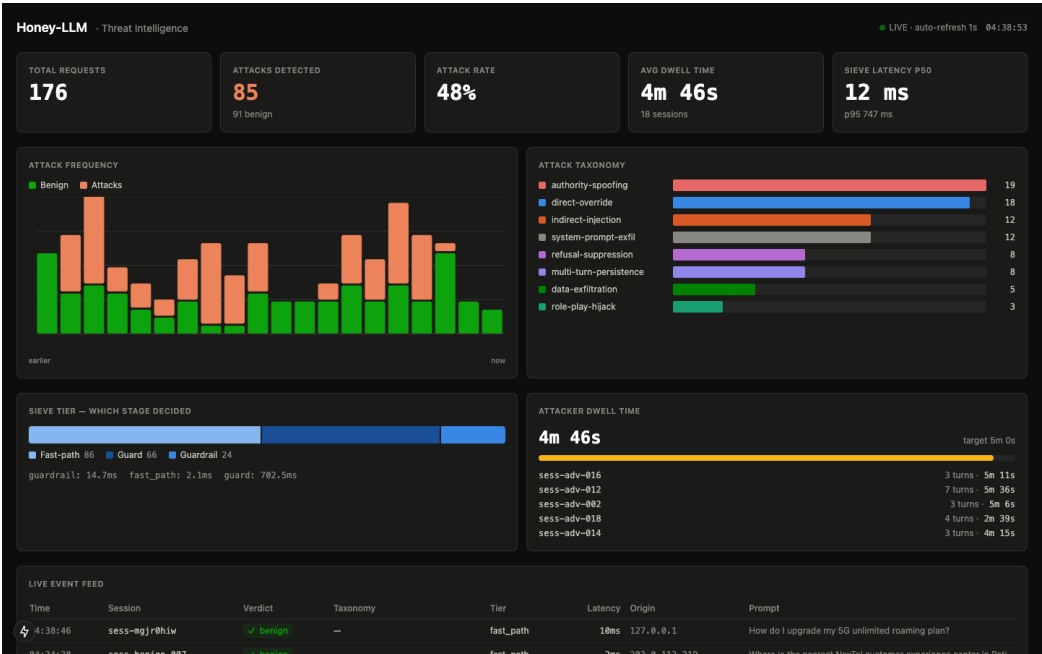
2. Admin Live Sieve Tracer (/admin)

Interactive decision tracing displaying Tier-0/1/2 latencies & verdicts live.



3. Dark SOC Threat Dashboard (/dashboard)

Real-time SOC threat intelligence with dwell meters and taxonomy stats.



Mid-Semester Progress Summary & Second-Half Roadmap

Mid-Semester Accomplishments (Phases 1–4 Completed)

- **[COMPLETED] Phase 1: Threat Taxonomy & Enterprise Sizing**

Formulated 8-class taxonomy; validated dual 8B concurrent inference on host compute without memory bottlenecks.

- **[COMPLETED] Phase 2: Intent Sieve Engine (98.3% Accuracy)**

Calibrated two-tier ensemble; achieved 98.3% in-the-wild detection with 0.0% false positives on domain traffic in ~2 ms.

- **[COMPLETED] Phase 3: 'Mirror Maze' Zero-Trust Honeypot**

Deployed 'Sarah' persona with synthetic bait; verified 5/5 container breakout tests with read-only rootfs.

- **[COMPLETED] Phase 4: Autonomous Guardrail Synthesis**

Engineered self-healing NeMo Colang loop; verified 10.4s hot-patching with zero service disruption.

Roadmap to End-Semester Submission (Phases 5 & 6)

- **[ROADMAP] Phase 5: Forensic Telemetry & SOC Intelligence Dashboard**

- Finalize sub-second real-time SSE websocket polling for live SOC visualization.
- Complete multi-turn attacker session replay and dynamic dwell time analytics.
- Export standardized STIX / TAXII threat intelligence feeds for enterprise SIEM.

- **[ROADMAP] Phase 6: Empirical Red-Teaming & Stress Testing**

- Execute scaled adversarial campaigns via **Microsoft PyRIT** across 12+ prompt obfuscation converters (Base64, ROT13, Leetspeak, Unicode confusables).
- Conduct multi-user concurrency stress testing (>100 concurrent sessions).
- Author the final Capstone Thesis and prepare peer-reviewed conference manuscript.

Key References (IEEE Style)

Primary Academic Literature & Framework Standards

- [1] M. Sladic, V. Valeros, C. Catania, and S. Garcia, "LLM in the shell: Generative honeypots," in *Proc. 2024 IEEE European Symposium on Security and Privacy Workshops (EuroS&PW;)*, Vienna, Austria, pp. 412–421, Jul. 2024.
- [2] H. T. Otal and M. A. Canbaz, "LLM Honeypot: Leveraging large language models as advanced interactive honeypot systems," in *Proc. 2024 IEEE Conference on Communications and Network Security (CNS)*, Taipei, Taiwan, pp. 1–9, Oct. 2024.
- [3] D. Ayzenshteyn, R. Weiss, and Y. Mirsky, "Cloak, Honey, Trap: Proactive defenses against LLM agents," Ben-Gurion University of the Negev, *USENIX Security Symposium*, 2025.
- [4] NVIDIA, "NeMo Guardrails Documentation: Programmable Rails with Colang 2.0," *NVIDIA Developer Docs*, Internet: <https://docs.nvidia.com/nemo/guardrails/>, 2024.
- [5] Meta AI, "Llama Guard 3: Developing safe and responsible generative AI models," *Meta Research Technical Report*, 2024.
- [6] P. Chao, A. Robey, E. Dobriban, H. Hassani, G. J. Pappas, and E. Wong, "JailbreakBench: An open robustness benchmark for jailbreaking large language models," in *Proc. NeurIPS*, Dec. 2024.
- [7] Microsoft, "Python Risk Identification Tool for Generative AI (PyRIT)," *Microsoft Security AI Research*, Internet: <https://github.com/Azure/PyRIT>, 2024.
- [8] OWASP Foundation, "OWASP Top 10 for Large Language Model Applications (v1.1)," *OWASP GenAI Security Project*, 2023.